Security Incident Postmortem: SEC-2026-014

Version	Date	Owner	Distribution	Change
v1.0	Aug 14, 2026	Kenji Torres (IC, SecEng)	incident-sec-2026-014 list, Legal	final after counsel review

CONFIDENTIAL. Security Engineering. Incident SEC-2026-014, severity 1. Status: resolved. Author: Incident Commander, Security Engineering. This postmortem is privileged and prepared at the direction of counsel. Do not share outside the incident distribution list.

Summary. On July 28, 2026, between 02:14 and 05:51 UTC, an unauthorized party used a leaked service account token to read objects from a storage bucket named cm-prod-exports-eu. The bucket held scheduled CSV exports for 37 customers. Approximately 2.3 gigabytes of data was downloaded, including export files for Bramblewood Retail Group and Ostrander Mutual Insurance. No evidence of access to the primary warehouse or customer credentials was found.

Root cause. A long lived service account token for the export scheduler was committed to a public fork of an internal Helm chart by a contractor on July 19. The token had read access to every export bucket instead of being scoped per customer. Our secret scanning ran only on the main organization repositories and did not cover forks owned by personal accounts.

- 02:14 UTC: first anomalous ListObjects call from an IP address in a hosting provider range
- 03:02 UTC: data egress alert fires but is routed to a deprecated pager rotation
- 05:37 UTC: on call SRE notices egress graph during unrelated work and escalates
- 05:51 UTC: token revoked and bucket policy locked down
- July 29: forensic image captured, outside counsel engaged
- August 2: notifications sent to 37 affected customers

Impact. Thirty seven customers were notified. Two customers, Bramblewood and Ostrander, have requested contractual credits totaling 186,000 dollars. Legal assesses that EU data protection notification was required and it was filed within 72 hours. Exported files for 4 customers contained personal data of end users, approximately 41,000 records.

What went well. Once escalated, the token was revoked within 14 minutes. Access logs were complete because we had enabled object level logging in May. Customer communication was coordinated with legal and went out within five days.

What went poorly. The egress alert routed to a rotation that was retired in March. The contractor had standing access to production Helm values. Token lifetime was unlimited. Detection took 3 hours and 23 minutes.

Customer follow up. Each affected customer received a written incident report, a list of the specific export files accessed and the time window of access. Account directors held calls with all 37 customers within ten days. Two customers requested on site security reviews, which are scheduled for November.

Detailed timeline (UTC)

Time	Event	Source
07-19 16:42	contractor pushes helm-values fork incl. export-scheduler token	GitHub audit
07-27 23:10	token observed in public code search index	threat intel, retro
07-28 02:14	first ListObjects from 185.x.x.x (hosting ASN)	bucket access log
07-28 02:19	bulk GetObject begins, ~4 req/s	bucket access log

Time	Event	Source
07-28 03:02	egress anomaly alert to #pager-data-legacy	alertmanager
07-28 04:48	access pattern changes, second IP	bucket access log
07-28 05:37	SRE (J. Wallin) notices egress graph, pages SecEng	Slack
07-28 05:51	token revoked, bucket policy deny-all	cloud audit
07-28 06:30	incident channel opened, IC assigned	Slack
07-29 11:00	outside counsel engaged	Legal
07-30 18:00	EU DPA notification filed	Legal
08-02 15:00	customer notifications sent (37)	CS

Affected data

Category	Customers	Files	Records w/ personal data
Sales exports	21	1,140	0
Marketing lists	6	212	38,700
Ops metrics	8	606	0
HR headcount	2	31	2,300

Contributing factors

1. Token lifetime unlimited and scope not per tenant. 2. Secret scanning excluded forks. 3. Alert route pointed at retired rotation; no test of alert delivery since March. 4. Contractor offboarding from the earlier project was incomplete, so they still had read access to helm-values. 5. No egress rate limit on export buckets.

Blamelessness note: the contractor followed the documented process for forking charts, which itself was the problem. The doc has been rewritten.

Action items. Rotate all service account tokens to 12 hour workload identity credentials by September 30 (owner: Platform). Extend secret scanning to forks and contractor accounts (owner: Security). Scope export credentials per customer (owner: Data Platform). Audit all alert routes quarterly (owner: SRE). Remove contractor access to production values files (owner: IT). Status of these items is tracked in ticket SEC-ACT-221.

Action items (tracked in SEC-ACT-221)

#	Action	Owner	Due	Status
1	workload identity for all service accounts, 12h creds	Platform	Sep 30	done
2	secret scanning on forks and contractor accounts	Security	Sep 15	done
3	per tenant export credentials	Data Platform	Oct 15	done
4	quarterly alert route audit	SRE	Oct 1	done
5	remove contractor access to prod values	IT	Oct 15	slipped Oct 31
6	egress rate limit on export buckets	Data Platform	Oct 31	in progress

Lessons for other teams: any credential that never expires will eventually leak. Any alert that has not fired in six months should be test fired. Any access granted for a project needs an end date tied

to that project.

Questions about this postmortem go to Kenji Torres. Do not share outside the distribution list; customer facing summaries are maintained by Legal.